



PROGRAMA AVANZADO · BLOQUE I — CIBERSEGURIDAD

MÓDULO 3 · ARQUITECTURA

Arquitecturas de Ciberseguridad

Del riesgo a la decisión de diseño · Escenario: Telvora Communications

Duración del módulo: 7 h (3 sesiones) · Diseño · Zero Trust · Red · Cloud · Validación

Los cinco bloques del módulo

A		Del riesgo a la arquitectura	Arquitectura ≠ diagrama, trust boundaries, principios de diseño y attack paths
B		Zero Trust	Qué no es, NIST SP 800-207, PDP/PEP, contexto y 800-207A cloud-native
C		Arquitectura de red y trazabilidad	SABSA/TOGAF, segmentación, controles (NGFW/WAF/IDS/EDR) y telemetría
D		Cloud, contenedores y DevSecOps	Responsabilidad compartida, Kubernetes, APIs, SASE, DevSecOps y multicloud
E		Validación y práctica	Validación de arquitectura, ADRs, riesgo residual y los laboratorios



BLOQUE A



Del riesgo a la arquitectura

Arquitectura ≠ diagrama · trust boundaries · principios de diseño · attack paths



Una arquitectura no es un diagrama bonito



Un diagrama

Cajas y flechas. Bonito, pero no dice qué confías, qué permites ni qué pasa si falla.



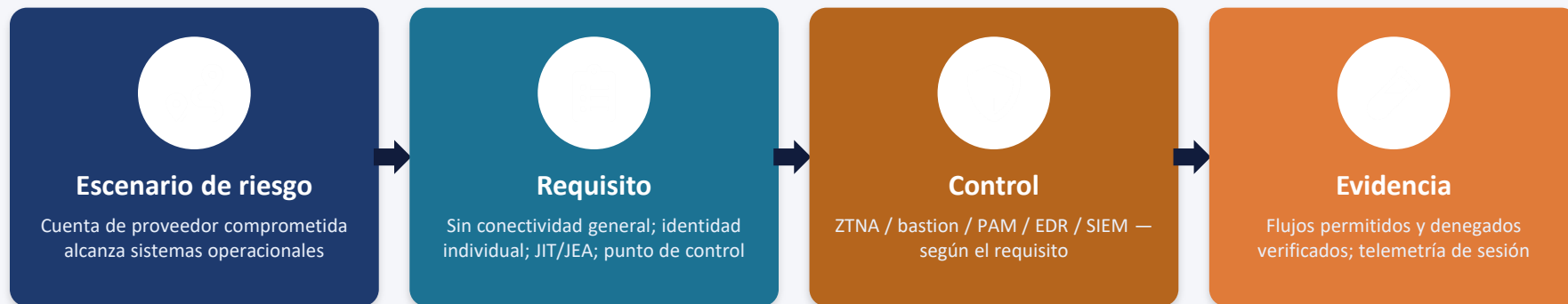
Una arquitectura

Decisiones · supuestos · trust boundaries · controles · flujos permitidos · verificación · trade-offs — todo trazable a riesgos concretos.

✗ **Pregunta equivocada:** «¿Qué firewall ponemos?»

✓ **Pregunta correcta:** «¿Qué escenarios de riesgo debemos reducir y qué propiedades debe garantizar la arquitectura?»

Riesgo → requisito → control → evidencia



Requisito ≠ patrón ≠ producto

Requisito

Todo acceso admin a NMS-PROD mediado, autenticado y auditado

Patrón

Privileged Access Workstation + PAM + bastion/jump

Producto

Marcas concretas — se eligen después, no antes

Un trust boundary no es solo una VLAN



Existe un límite de confianza cuando cruzar de un contexto a otro cambia las suposiciones de confianza o exige una decisión de seguridad.

Ejemplos de cruce

- ➔ Internet → servicio público
- ➔ Usuario → plano administrativo
- ➔ Proveedor → entorno Telvora
- ➔ Aplicación → base de datos
- ➔ Workload → secreto
- ➔ Cluster K8s → API cloud
- ➔ IT → OT

En cada cruce hay que responder

- ➔ ¿Quién inicia el flujo y hacia qué destino?
- ➔ ¿Cómo se autentica el origen y se autoriza la acción?
- ➔ ¿Qué contexto participa en la decisión?
- ➔ ¿Qué control aplica la política?
- ➔ ¿Qué ocurre si el control falla?
- ➔ ¿Qué telemetría se produce y quién investiga?

Cinco principios de diseño seguro



Least privilege

WHO · WHAT · WHERE · WHEN · WHY.
También en duración del privilegio.



Minimizar superficie

Menos servicios, interfaces admin,
protocolos legacy y secretos estáticos.



Separación de funciones

Nadie solicita, aprueba, ejecuta y
oculta la misma operación crítica.



Fail secure / safe failure

Decidir el comportamiento ante fallo.
Break-glass gobernado, no
permanente.



Defense in depth — capas con modos de fallo distintos y señales independientes:

MFA anti-phishing

postura disp.

PAM/JIT

bastion

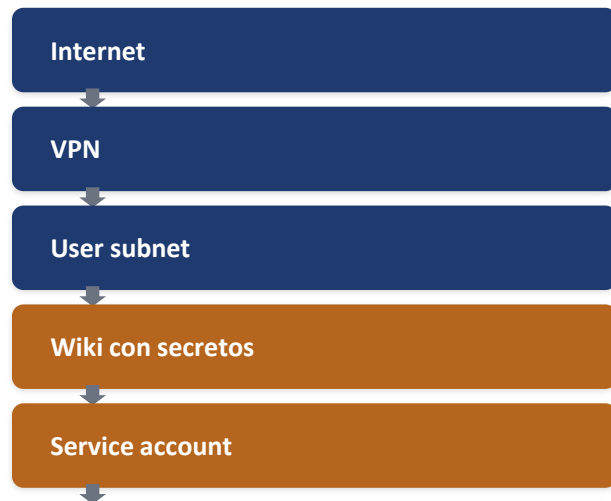
segmentación

EDR

SIEM

La pregunta avanzada: ¿qué capas siguen funcionando cuando una anterior ya ha fallado?

Attack paths: la suma crea el camino



Cada componente parece razonable; la combinación no

Además de controles individuales, analiza:



Relaciones de confianza



Caminos privilegiados



Dependencias de identidad



Reachability



Secretos



Blast radius



El objetivo no es «cero caminos». Es eliminar o romper los caminos que convierten un compromiso plausible en un impacto crítico. Una arquitectura puede cumplir la checklist y mantener intacto un attack path.



BLOQUE B



Zero Trust

Qué no es · NIST SP 800-207 · policy decision/enforcement · contexto · 800-207A



Zero Trust no es un producto que se compra

Zero Trust **NO** es sinónimo de:

✗ MFA

✗ VPN moderna

✗ microsegmentación

✗ SASE

✗ un producto ZTNA

✗ «no confiar en nadie»



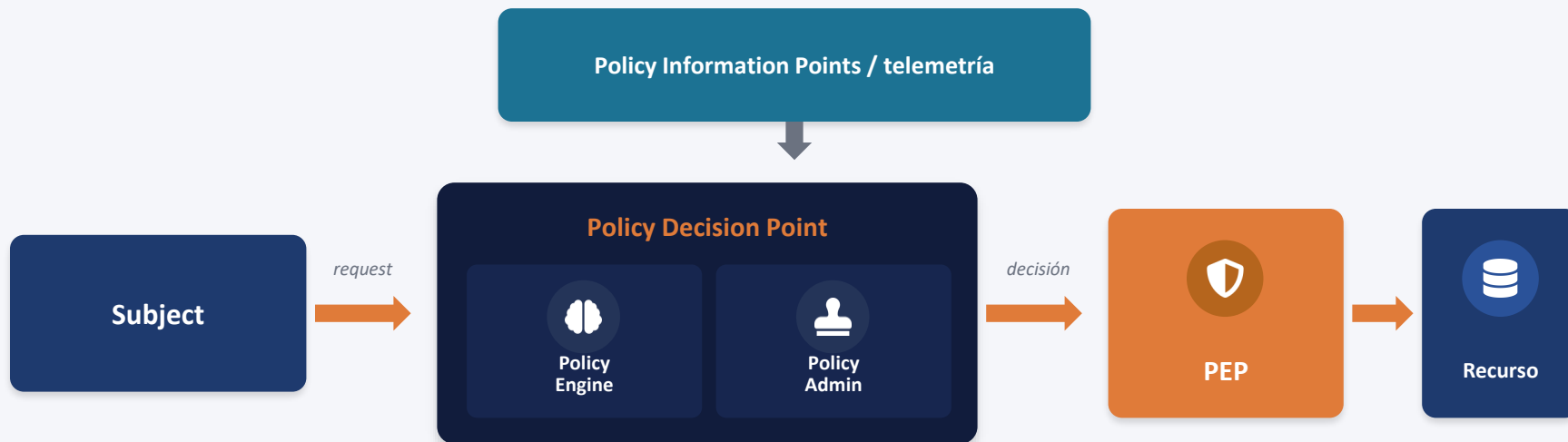
NIST SP 800-207 — el cambio de paradigma

No se concede confianza implícita por la ubicación de red ni por la propiedad del activo. La protección se centra en los recursos y la autenticación/autorización se evalúan antes de establecer la sesión.



Sin visibilidad y sin enforcement, Zero Trust es solo una intención. No es un destino que se compra, es una propiedad que se diseña y se verifica.

NIST SP 800-207: componentes lógicos



Policy Engine: toma la decisión. **Policy Administrator:** establece o termina la comunicación. **PEP:** ejecuta la decisión en el camino de acceso.
La implementación puede adoptar muchas formas tecnológicas: lo que importa es el modelo lógico.

La decisión de acceso, expresada como política

Ejemplo — acceso administrativo a NMS-PROD

ALLOW admin access to **NMS-PROD**

IF

user ∈ NOC-Privileged
AND device = managed + compliant
AND auth = phishing-resistant MFA
AND privilege = approved JIT
AND origin = admin access service
AND session risk < threshold



PDP · decide

Evalúa TODAS las condiciones antes de conceder la sesión.



PEP · aplica

Ejecuta la decisión en el camino real de acceso.

Acceso consciente del contexto



Identidad y rol



Recurso solicitado



Postura del dispositivo



Ubicación / red



Señales de riesgo



Threat intelligence



Historial de sesión



Hora



Sensibilidad del recurso



Comportamiento

«**Always verify**» ≠ **reautenticar en cada paquete**. Significa que el acceso se sustenta en políticas y señales que pueden reevaluarse continuamente.

La **arquitectura necesita**: identidad fuerte · inventario/estado de activos · enforcement · telemetría · capacidad de revocación · feedback loop.

En cloud-native, la identidad del usuario no basta



Tráfico este-oeste: una segmentación por subnet permitiría demasiado.



Enfoque granular por identidad de workload

- ✓ Workload / service identity
- ✓ API + ingress/egress gateways
- ✓ Service mesh + mTLS
- ✓ Authorization policy
- ✓ SPIFFE/SPIRE (identidad de workload)



La lección

No es «hay que instalar un service mesh». Es que la arquitectura debe poder expresar y aplicar quién puede llamar a qué servicio, y en qué condiciones — aunque ambos compartan red o cambien de IP.



BLOQUE C



Arquitectura de red y trazabilidad

SABSA/TOGAF · segmentación · microsegmentación · controles · telemetría

SABSA y TOGAF: del negocio al control



SABSA · business-driven

Business requirement Intervenciones urgentes del NOC 24x7



Security attribute Accountable + Resilient + Controlled



Architecture requirement Acceso de emergencia atribuible y monitorizado



Controls PAM + break-glass governance + session logging



TOGAF · integrar seguridad

La seguridad no es una fase posterior: se integra en la arquitectura empresarial (Standard, 10th Edition).



Business Architecture



Data Architecture



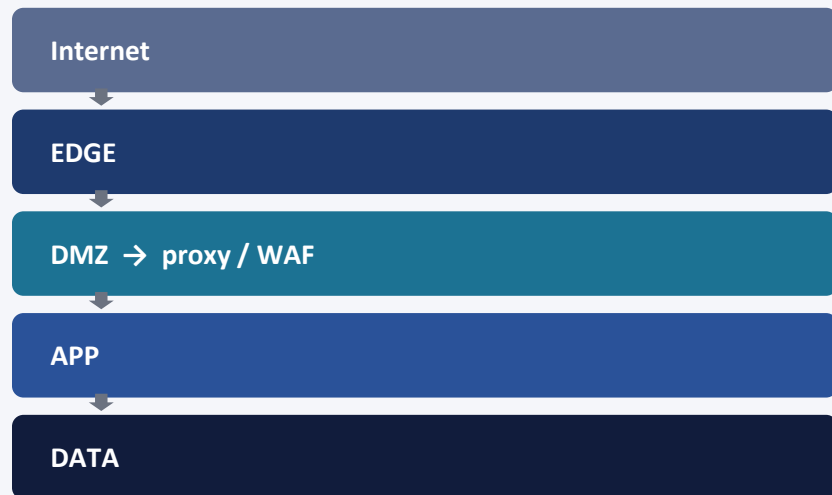
Application Architecture



Technology Architecture

SABSA y TOGAF no compiten: TOGAF aporta el proceso de arquitectura; SABSA, la trazabilidad business-driven de seguridad y riesgo.

Segmentación por intención



→ CORP USERS → servicios aprobados

→ ADMIN → management plane

→ THIRD PARTY → broker/bastion

→ IT ↔ IT/OT DMZ ↔ OT



Default deny. La dificultad real es descubrir qué flujos son necesarios: dependency mapping, flow logs, owners, staged rollout.

Cada flecha debe poder justificarse.

Microsegmentación y management plane



Microsegmentación

Reduce la granularidad del dominio de confianza. Se implementa con:

- ✓ Host / distributed firewalls
- ✓ Workload labels · security groups
- ✓ Kubernetes NetworkPolicies
- ✓ Identity-aware policy

No es «una política por VM»: el exceso es inoperable.



Management plane

Separarlo y protegerlo: es un objetivo de altísimo valor para un atacante.

- ¿Desde dónde se administra el firewall?
- ¿Quién administra el hypervisor?
- ¿Cómo se accede a switches/routers?
- ¿Cómo se administran los clusters cloud/K8s?
- ¿Cómo se recupera si IAM no funciona?

No confundir función con producto



NGFW

Enforcement L3/L4, app-awareness, segmentación, egress.

Límite: No ve el tráfico que no atraviesa su punto de enforcement.



IDS / IPS

IDS observa y alerta; IPS puede bloquear.

Límite: Miles de alertas sin triage no son detección.



WAF

Reduce ataques web y aporta virtual patching.

Límite: No corrige autorización rota ni lógica de negocio.



EDR / XDR

Telemetría y respuesta en endpoint/workload.

Límite: Pregunta: ¿qué fuentes integra y qué gaps deja?



SIEM

Correlación y analítica sobre logs.

Límite: No detecta por existir: define qué logs por escenario.



SOAR

Automatiza respuesta con playbooks.

Límite: Automatizar una mala decisión = equivocarse más rápido.

Telemetría desde el principio, no después



Para cada control crítico

- ¿Qué evento produce y quién lo recibe?
- ¿Cuánto tiempo se conserva?
- ¿Qué campos necesita?
- ¿Cómo se correlaciona con identidad/asset?
- ¿Hay sincronización temporal?
- ¿Qué detección se apoya en él?
- ¿Cómo sabemos si deja de enviar datos?



Ejemplo: cuenta break-glass

No basta con registrar el login. Necesitamos:



identidad · dispositivo · IP · timestamp



contexto MFA/bypass



recurso accedido · comandos



duración · ticket de emergencia

...y una regla que detecte CUALQUIER uso, no solo el anómalo.

Una arquitectura sin observabilidad no distingue «seguro» de «no lo sabemos».



BLOQUE D



Cloud, contenedores y DevSecOps

Responsabilidad compartida · Kubernetes · APIs · SASE · DevSecOps · multicloud

No existe una única frontera universal

	IaaS	PaaS	SaaS
Data	Cliente	Cliente	Cliente
Identity / config	Cliente	Cliente	Cliente
Application	Cliente	Compartida	CSP
Runtime / OS	Cliente	CSP	CSP
Hypervisor / físico	CSP	CSP	CSP

Security OF the cloud → CSP.
Security IN the cloud → cliente.
«Shared fate» no elimina tu
responsabilidad sobre identidad,
config y datos.

Errores frecuentes

- storage público
- reglas 0.0.0.0/0
- roles IAM amplios
- claves estáticas / secretos en IaC
- logging deshabilitado

■ Cliente ■ Compartida ■ CSP

Kubernetes: proteger build-time y runtime



BUILD-TIME

Supply chain

registry de confianza · signing/SBOM · scan · digests pinned

Identity

RBAC mínimo · service accounts · workload identity

Policy

admission policy · policy-as-code · guardrails



RUNTIME

Workload

non-root · read-only FS · drop capabilities · seccomp · limits

Network

default-deny NetworkPolicies · ingress/egress · service mesh

Detection

audit logs · runtime telemetry · alertas de privilegios

OWASP Kubernetes Top 10 (2025): configuraciones inseguras, autorización excesiva, fallos de secretos, falta de policy enforcement y de segmentación de red.

Una API expuesta es un trust boundary programable



Preguntas arquitectónicas

- ¿Quién autentica y quién autoriza cada objeto?
- ¿Cómo se validan los tokens?
- ¿Cómo se limita el abuso / rate?
- ¿Cómo se protegen los secretos?
- ¿Qué datos devuelve?
- ¿Qué ocurre entre servicios internos?
- ¿Qué se registra?



API Gateway

Centraliza auth, routing, rate limiting, validación básica y logging.

Pero no sustituye la autorización dentro de la aplicación.

OWASP ASVS 5.0

Convierte «aplicación segura» en requisitos verificables. Pregunta qué exigir en autenticación, autorización, sesión, cryptography, protección de datos y logging — en vez de «cumple el Top 10».

Patrones útiles, no arquitecturas obligatorias



CASB

Visibilidad y control de SaaS: discovery, DLP, acceso, posture. Su valor depende del modo de integración y visibilidad real.



SSE / SASE

SASE acerca red y seguridad a usuarios y sedes distribuidas; SSE agrupa la seguridad sin el componente WAN.



SD-WAN seguro

Mejora conectividad y control central, pero no convierte la WAN en Zero Trust: evalúa control plane, cifrado e identidad.



No son obligatorios: son patrones útiles ante usuarios remotos, SaaS, cloud, sedes distribuidas y la necesidad de enforcement coherente. **Y recuerda: SD-WAN no es Zero Trust por defecto.**

DevSecOps: seguridad donde el feedback es útil



↺ feedback continuo hacia los requisitos



Policy-as-code

```
DENY deployment
IF public_ingress == true
AND classification == "internal"
```

Reduce la divergencia entre arquitectura aprobada y despliegue real.



Gates proporcionales al riesgo

No todo hallazgo debe romper el pipeline. Se pondera:

- ✓ severidad · exploitability
- ✓ exposición · activo
- ✓ controles compensatorios
- ✓ gobierno de excepciones

Multicloud: más control planes, más superficie



Multicloud puede aumentar...

- ✗ identidades y control planes
- ✗ herramientas y conexiones
- ✗ configuraciones y skills
- ✗ observabilidad fragmentada
- ✗ attack surface

«Tres nubes para ser más resiliente» no es una razón.



El control plane es el activo crítico

Comprometer una identidad privilegiada del control plane puede ser más grave que comprometer una VM. Protege:

- ✓ root / break-glass identities
- ✓ roles privilegiados · federación
- ✓ identidades de CI/CD · Terraform
- ✓ audit logging · políticas de org



BLOQUE E



Validación y práctica

Validación de arquitectura · ADRs · riesgo residual · laboratorios



Una arquitectura no termina en el diagrama



Debe existir evidencia de que...

- ✔ las reglas reales corresponden al diseño
- ✔ los flujos no autorizados fallan
- ✔ los logs llegan y las alertas disparan
- ✔ las identidades tienen los permisos esperados
- ✔ los break-glass funcionan y alertan
- ✔ los guardrails bloquean lo prohibido



Técnicas de validación

- ➔ firewall rule review
- ➔ connectivity testing · packet capture
- ➔ IDS test traffic
- ➔ config / IaC scanning
- ➔ attack path analysis
- ➔ adversary emulation · purple team
- ➔ cloud posture assessment
- ➔ architecture conformance review

Architecture Decision Records



Plantilla mínima

Decision · Status · Context

Risk scenarios addressed

Assumptions · Options considered

Rationale · Trade-offs

Controls required · Telemetry

Residual risks · Validation method

Review trigger / date

ADR-003

Todo acceso de proveedor a sistemas operacionales debe atravesar un broker/bastion administrado y no tendrá reachability directa desde la zona de terceros.



Un ADR conserva el contexto: permite revisar la decisión cuando cambian el contexto o las amenazas — no cuando alguien lo recuerda.

Un microchallenge y tres laboratorios



Microchallenge 3.A — Architecture under pressure: cinco decisiones aparentemente razonables; localiza trade-offs, trust assumptions y gaps.



Lab 3.1

Segmentation by Intent (pfSense)

Convertir una matriz de flujos en reglas reales y demostrar por evidencia que la segmentación funciona.



Lab 3.2

Detection Engineering (Suricata)

Elegir punto de sensor, generar tráfico, ajustar una regla y reducir falsos positivos sin perder el objetivo.



Lab 3.3

Cloud Architecture Review (IaC)

Revisar una arquitectura cloud sin desplegar: usar IaC como evidencia, detectar fallos y proponer guardrails.

Todo desemboca en la Mission 03 — Architecture Defence Pack: diagrama, ADRs, matriz de flujos, controles, telemetría, riesgos residuales y validación.



De productos a riesgos, decisiones y evidencia



Arquitectura ≠ diagrama

Decisiones, trust boundaries, controles y evidencia trazables a riesgos.



Zero Trust se diseña, no se compra

PDP/PEP, contexto, enforcement y telemetría — no un producto.



Segmentar es flujo explícito

Default deny; cada flecha justificada; protege el management plane.



Función ≠ producto

Cada control tiene un límite; combina capas con fallos independientes.



En cloud, identidad y config son tuyas

El control plane es el activo crítico en multicloud.



Sin validación no hay arquitectura

Evidencia de que lo permitido pasa y lo denegado falla; ADRs con residual.



✓ MÓDULO 3 COMPLETADO

A continuación

Módulo 4 — Ciberseguridad del Dato y Tecnologías Disruptivas

- Clasificación y ciclo de vida del dato · DLP
- Criptografía y PKI: AES, RSA, ECC, TLS, HSM/Vault
- IAM: MFA, SSO, OAuth 2.0, SAML, OIDC, PAM y ZSP
- Ciberseguridad en la nube y del IoT

«Ya sabemos qué arquitectura diseñar; ahora, cómo protegemos el dato y las identidades que la recorren.»